Asset ID	Asset Name	Threat	Vulnerability	Inherent Risk Score	Treatment Decision	Proposed Control & ISO 27001:2022 Annex A Mapping	Residual Risk Score
AST-01	Production Kubernetes Cluster (AWS EKS)	Unauthorized container escape or cluster takeover	Misconfigured RBAC permissions or unpatched container runtime vulnerabilities	20	Mitigate	Enforce strict least-privilege RBAC, automated container vulnerability scanning in pipelines, and network segmentation policies. (Annex A.8.9 / A.8.20)	4
AST-02	Multi-Tenant Customer Database (PostgreSQL)	SQL injection or unauthorized cross-tenant data access	Weak database encryption, exposed public endpoints, or missing input validation	25	Mitigate	Implement encryption at rest/in transit, private VPC subnet isolation, parameterized queries, and strict database security groups. (Annex A.8.24 / A.8.12)	5
AST-03	GitHub Enterprise Code Repositories (IP)	Malicious insider or credential theft exposing source code	Lack of branch protection rules, code secrets scanning, or hardware MFA on developer accounts	16	Mitigate	Enforce mandatory hardware-backed FIDO2 MFA, automated secrets scanning in git hooks, and strict code review pull-request policies. (Annex A.8.31 / A.9.4)	4
AST-04	Cloud Admin Access & AWS IAM Master Keys	Account takeover and full cloud infrastructure compromise	Long-lived static access keys and lack of multi-person authorization for critical actions	20	Mitigate	Mandate AWS IAM Identity Center with temporary SSO sessions, disable root user access keys, and enforce hardware tokens. (Annex A.9.2 / A.9.4)	4
AST-05	Corporate Identity Provider (Okta / Google Workspace)	Phishing, credential stuffing, and corporate takeover	Employees using weak passwords or lacking phishing-resistant multi-factor authentication	15	Mitigate	Enforce enterprise-wide WebAuthn/YubiKey hardware tokens, automated device posture checks, and session time limits. (Annex A.5.17 / A.9.4)	3
AST-06	Employee Workstations / Laptops	Phishing & Malware Execution	Lack of regular security awareness training or multi-factor authentication for corporate apps	15	Mitigate	Enforce mandatory security awareness training, phishing simulation tests, and hardware-backed MFA. (Annex A.6.3 / A.9.4)	3
AST-07	CI/CD Deployment Pipeline (GitHub Actions)	Supply Chain Code Injection	Using unvetted third-party open-source libraries and scripts without security scanning	20	Mitigate	Integrate automated Software Composition Analysis (SCA) and secure code reviews into the pipeline. (Annex A.8.8 / A.8.31)	4
AST-08	Encrypted Customer Backups (AWS S3)	Ransomware Deletion or Data Corruption	Backups stored in the same administrative account without write-once-read-many (WORM) protections	20	Mitigate	Enable AWS S3 Object Lock (WORM state), cross-region replication, and strict multi-person authorization for deletion. (Annex A.8.13 / A.8.24)	4
AST-09	Internal HR & Employee Database	Unauthorized Internal Data Harvesting	Overly permissive default role-based access control (RBAC) allowing all staff to view records	15	Mitigate	Implement strict Principle of Least Privilege (PoLP) and quarterly manual access reviews. (Annex A.9.1 / A.9.2)	3
AST-10	Office Wi-Fi & Network Infrastructure	Rogue Device / Man-in-the-Middle Attack	Open corporate Wi-Fi network or weak pre-shared keys for office visitors and staff	12	Mitigate	Deploy WPA3-Enterprise 802.1X authentication, guest network segmentation, and certificate-based device profiling. (Annex A.7.4 / A.8.21)	3
AST-11	Third-Party Vendor API Integrations	Third-Party Data Breach / Supply Chain Compromise	Unvetted vendor security posture, overly broad OAuth scopes, and lack of API rate-limiting	16	Mitigate	Conduct rigorous vendor security assessments, enforce least-privilege OAuth scopes, and monitor API traffic anomalies. (Annex A.5.19 / A.8.28)	4
AST-12	SIEM & Log Management Infrastructure (Wazuh / Splunk)	Log Tampering or Blind Spots in Monitoring	Unencrypted log transmission, lack of log retention policies, or missing agents on core servers	15	Mitigate	Centralize log aggregation, enable immutable write-once log storage, and enforce automated alerting for critical security events. (Annex A.8.15 / A.8.16)	3
AST-13	Customer Support Ticketing System (Zendesk / Jira)	Social Engineering / Unauthorized PII Access by Support Agents	Lack of ticket data masking, excessive agent permissions, or weak session controls	12	Mitigate	Mask sensitive customer data fields, enforce role-based ticket access, and audit agent activity logs. (Annex A.8.11 / A.9.4)	3
AST-14	Public-Facing Corporate Website & Marketing CMS	Website Defacement or Malicious Redirection	Outdated CMS plugins, unpatched vulnerabilities, or weak administrator passwords	12	Mitigate	Implement automated plugin vulnerability scanning, Web Application Firewall (WAF), and isolated hosting architecture. (Annex A.8.8 / A.8.26)	3
AST-15	Disaster Recovery & Business Continuity Plan (DRP/BCP)	Extended Service Outage due to Ransomware or Cloud Region Failure	Untested backup restoration procedures and lack of documented failover runbooks	20	Mitigate	Conduct annual full-scale disaster recovery drills, establish multi-region redundancy, and maintain documented BCP runbooks. (Annex A.5.29 / A.5.30)	4